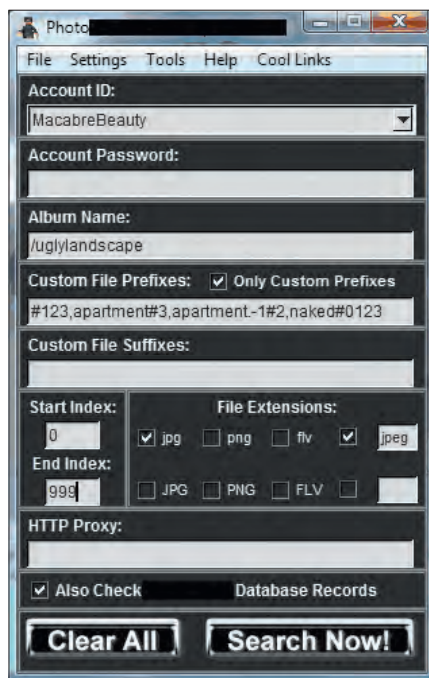


of having to provide a service that is both public and private, often letting the users choose a comfortable level. The security and privacy features of even the top social networking sites are full of holes. Social networking sites constantly change their policies, as well as the back ends of their web sites to address these issues. The APIs available for third party content is the biggest concern right now. Applications on Facebook, for example, have access to almost any information stored on your profile, as well as the profiles of your friends. An application developer can easily access this information, and there are almost no regulatory forces that review the activities of application developers. To view a demonstration of the extent to which applications can access the data on your account, and the accounts of your friends, try out the Facebook privacy quiz at http://apps.facebook.com/aclunc_privacy_quiz/. The results are a little chilling, as the app can start displaying images and comments from your friend's profiles as well. Even if you are careful about which applications you allow access to, if your friends use dubious applications, the developers can access your information as well.

Some implementations of the Twitter API allows third parties to host their own applications, on servers that are independent of Twitter. This means that your login details are stored on these third party servers, although you are still using the services of Twitter. Often, the passwords are stored in plain text, and not even encrypted over the network. The developers do not like it, and for some reason, there is no big fuss over this issue yet.

Photo sharing web sites such as Photobucket, ImageShack and TinyPic are monitored by peeping Toms for compromising photos of people. Orkut and Facebook are also targetted. Although these websites offer privacy settings, if the direct URL to a resource is known, it can be accessed. A "fuser" is a software or web service that allows people to search for these images using a pattern, either a file name of a particular kind of camera, or custom tags used by the uploader. This screenshot of a software with a name too obscene to be published, shows a fuser looking for images with

either "apartment" or "naked" as associated text strings in the name, tags or comments.



A feature rich fuser software

Software Trackers

Cyber Criminals have a number of reasons to monitor your web activity. The best Trojans and worms around now, don't give any visible signs of infection, and are pretty versatile. Many of them are in constant touch with remote servers, that keep changing to avoid detection. Updates and patches are often relayed to the malware. The malware does not need to monitor and send back all the activities on the infected machine. There are two parts to malware such as a Trojan or a worm. One part is the infecting agent, which spreads from machine to machine. The other part, called the payload, is a set of instructions, typically used to send back data. This can be a small, simple keylogger, that monitors, say 12 characters before and after the "@" symbol, then sends it back to the cyber criminals. Even if you don't use the "@" symbol to login, these payloads can monitor every time an alphanumeric string has numbers and odd characters used without spaces. This is enough to send back the username and password to your e-mail. Some of these payloads are advanced enough to peek into your RAM for patterns of data. This

means that if you are infected, and enter your credit card number even in a secure website, the data can be intercepted on its way from your keyboard, and sent to these criminals.

This kind of malware is used for two primary purposes. The most common one is the creation of botnets for spamming. These botnets are easy to detect, very closely monitored, and easy to take down as well. There are another set of botnets used for information harvesting, and financial scams. These botnets are smaller, more focussed, difficult to detect, and very advanced. The botnets have version numbers, and contrary to popular notions, the malware thrives by not spreading as fast as it can. Instead, it thrives by avoiding detection, and allows whoever is controlling the botnet to have a secured environment to work in. The copy protection on the latest version of the Zeus botnet analyses the system, and locks itself to the particular machine. Zeus is used to collect financial information en masse from e-commerce and banking servers. Zeus also collects login details to a wide range of web sites, including Facebook



A map of the Zeus botnet

and MySpace The reach of Zeus is world-wide, and India is among the most infected countries.

Zeus is an evolved form of malware, using many of the same principles as the Conficker outbreak. Even up to date anti-virus software do not detect or clean a Zeus infection. Access to Zeus commands as much as US\$ 4,000 (Rs. 1,80,000), when it is sold on underground networks. The biggest problem is that major security breaches are hushed up and never made public. This is because financial institutions do not want to disclose any information on the extent of the compromise, or the methods used. **[4]**